Management Review Procedure

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This procedure defines the process for conducting management reviews of the ISMS to ensure its continued suitability, adequacy, effectiveness, and alignment with business objectives and compliance requirements.

Scope

Covers the entire ISMS scope of Stark Industries Inc., including cloud infrastructure, SaaS platform development, internal tools, supporting processes, and third-party management.

Objective

- Ensure the ISMS aligns with business strategies and risk tolerance
- Confirm ISMS objectives (Clause 6.2) are being met
- Identify opportunities for continual improvement
- Address any nonconformities or external changes affecting the ISMS

Management Review Inputs

The following inputs must be considered in each review:

- Results of **Internal Audits (Clause 9.2)**
- Feedback from stakeholders (e.g. customers, partners)
- Information on security incidents, breaches, and nonconformities
- Monitoring and measurement results (KPIs, incidents, backups, training)
- Updates on risk assessments and treatments
- Status of corrective and preventive actions (Clause 10.1)
- Changes in external or internal issues (e.g., regulations, threats)
- Progress toward information security objectives (Clause 6.2)
- Resource needs (e.g., staffing, tools, training)

Management Review Outputs

The management review must result in:

- Decisions and actions related to improvements in the ISMS
- Updates to the risk treatment plan and SoA if required
- Allocating necessary resources (e.g., personnel, tools)
- Approvals of revised policies or procedures
- Identification of new risks and opportunities

Participants

Role	Responsibility
CEO	Overall ISMS oversight and strategic decisions
Information Security Manager	Coordinates the review, prepares reports
GRC Analyst	Provides metrics, audit findings, risk updates
IT/Infra Engineer	Supplies operational performance data
Security Analyst	Shares incident reports, pen test results

Records of Management Review

- Agenda and attendance list
- Review meeting minutes, including decisions and action items
- Updated risk registers and SoA if applicable
- Evidence of assigned actions and follow-ups

Review and Updates

- This procedure is reviewed annually or after major changes to the ISMS
- Additional reviews may be scheduled following significant changes, incidents, or audits